

Test & QA Report

ArchViz Pro — AI Digital Twin Platform

Date: 28 July 2026

Build: main @ ca0d9d5 · Version 1.0.0

Verdict: PASS (1 recommended fix)

Executive Summary

The application is healthy and production-shippable. Every automated check that can be run in the current environment passes: TypeScript type-checking, the production build, 15 server endpoint behaviors, 9 core-logic unit checks, and a real browser render with full interaction. The one medium-severity security issue found — an unauthenticated proxy on the legacy AI routes — has since been fixed and re-verified; a few minor items and one structural gap (no automated test suite / CI) remain.

Overall verdict: PASS — the medium open-proxy finding is now resolved.

Test Results

Suite	Result	Notes
TypeScript (tsc --noEmit)	PASS — 0 errors	Clean.
Production build (Vite + esbuild)	PASS	Client + server.cjs emitted.
Lint (npm run lint)	PASS	Lint maps to tsc.
Server smoke — unconfigured	PASS 9/9	503 degradation; health flags false.
Server smoke — configured	PASS 6/6	401 unauth; 400 on bad webhook signature.
Core logic units (BOM, geometry)	PASS 9/9	Grouping, cost parse, collision, room lookup.
Browser render + interaction	PASS	Mounts; tutorial / 2D toggle / legal modal work.

Two initial smoke “failures” were traced to a test-harness JSON-escaping bug; the endpoints were re-verified to return a correct 401 with valid request bodies.

Build Metrics (gzip)

Chunk	Size (gzip)	Chunk	Size (gzip)
main app	118.5 kB	genai (lazy)	61.3 kB
three.js	130.7 kB	react	4.2 kB
supabase	55.9 kB	CSS	9.8 kB

Vendor libraries are code-split and the AI SDK is lazy-loaded. The three.js chunk trips Vite’s >500 kB (raw) warning — expected for a 3D engine and already isolated into its own chunk.

Findings by Severity

RESOLVED	Legacy AI proxy open-endpoint — FIXED
Previously POST /api/digitize-blueprint and /api/rebuild-from-prompt fell back to the server GEMINI_API_KEY with no authentication, so anyone who found the URLs could consume the platform Gemini quota unauthenticated and unmetered. Fixed: these routes now use the x-gemini-api-key header (the caller’s own key, unmetered) when supplied, and when it is absent they no longer touch the platform key — they delegate to the hosted, metered path, which requires a Supabase JWT plus workspace membership and enforces the plan’s monthly credit limit. Re-verified: a no-key, no-auth request now returns 401/403/503 instead of a free generation.	
LOW	Malformed JSON returns HTML, not JSON
Express’s default body-parser error returns an HTML “Bad Request” page rather than a JSON error envelope. Fix: add a small JSON error-handling middleware.	
LOW	Fonts loaded from an external CDN

src/index.css imports fonts from fonts.googleapis.com (the source of the single console error observed in the sandbox, where the CDN is blocked). Minor reliability/privacy nit. Fix: self-host the fonts to remove the third-party request.

LOW**No @types/react**

JSX is loosely typed, so type-checking cannot catch prop/JSX mistakes. Fix: add @types/react and @types/react-dom and resolve the surfaced any usages in a dedicated pass.

GAP**No automated test suite or CI**

There are no test files and no vitest/jest/CI configuration; all verification is manual. For a product now handling auth, billing and row-level security, this is the largest structural risk. Recommendation: add vitest for the pure utilities (bom, geometry, layout, watermark, plan gating) and a GitHub Actions workflow running tsc + build + tests on PRs.

Not Verified Here (needs a staging environment)

- **Stripe** end-to-end (Checkout → webhook → subscriptions row). Prices exist; server env not yet set.
- **Supabase RLS** at runtime (tenant isolation, team permissions). SQL is written defensively; run one live cross-tenant test.
- **Hosted AI** with a real Gemini key (metering and cache-hit path).

Strengths

- Clean type-check and build; no runtime console errors originating from app code.
- Sound security fundamentals: secrets kept server-side, JWT verification, workspace-scoped RLS, signature-verified webhooks, owner-only billing, Free-plan watermarking.
- Graceful degradation: features return 503 / empty states rather than crashing when a migration or env var is missing.
- Well-factored shared utilities and a consistent, branded UI that renders and interacts correctly.

Recommendation

Ship-ready for a controlled launch. The medium open-proxy finding has been closed, so a server-side Gemini key can now be enabled safely. As fast-follows: add a vitest suite plus GitHub Actions CI, self-host fonts, and add @types/react.

ArchViz Pro — AI Digital Twin Platform · Automated QA verification report. This report reflects checks executed in a sandbox without live third-party credentials; items under “Not Verified” require a staging environment.